

MOTIVATION

Developers are increasingly using AI-assisted code generation tools, such as GitHub Copilot, for code generation. These AI models learn from patterns that emerge in the dataset used for their training. Some datasets may contain vulnerabilities and harmful coding practices (smells), which may leak into the output of these models. Our research created a dataset with real-world solved CVE in pull requests to benchmark LLMs.

BACKGROUND

Vulnerable code: Vulnerable code refers to coding techniques that contain weaknesses, flaws, or security issues that can be exploited by attackers to compromise the system, gain unauthorized access, or cause unwanted behaviors in the system.

```
1 from django.db import connection
2
3 def show_user(username):
4     """
5     Create a cursor to get the user info
6     from the 'users' table, then return it.
7     """
8     cursor = connection.cursor()
9     cursor.execute("SELECT * FROM users WHERE username = '%s'" % username)
10    user = cursor.fetchone()
11    return user
```

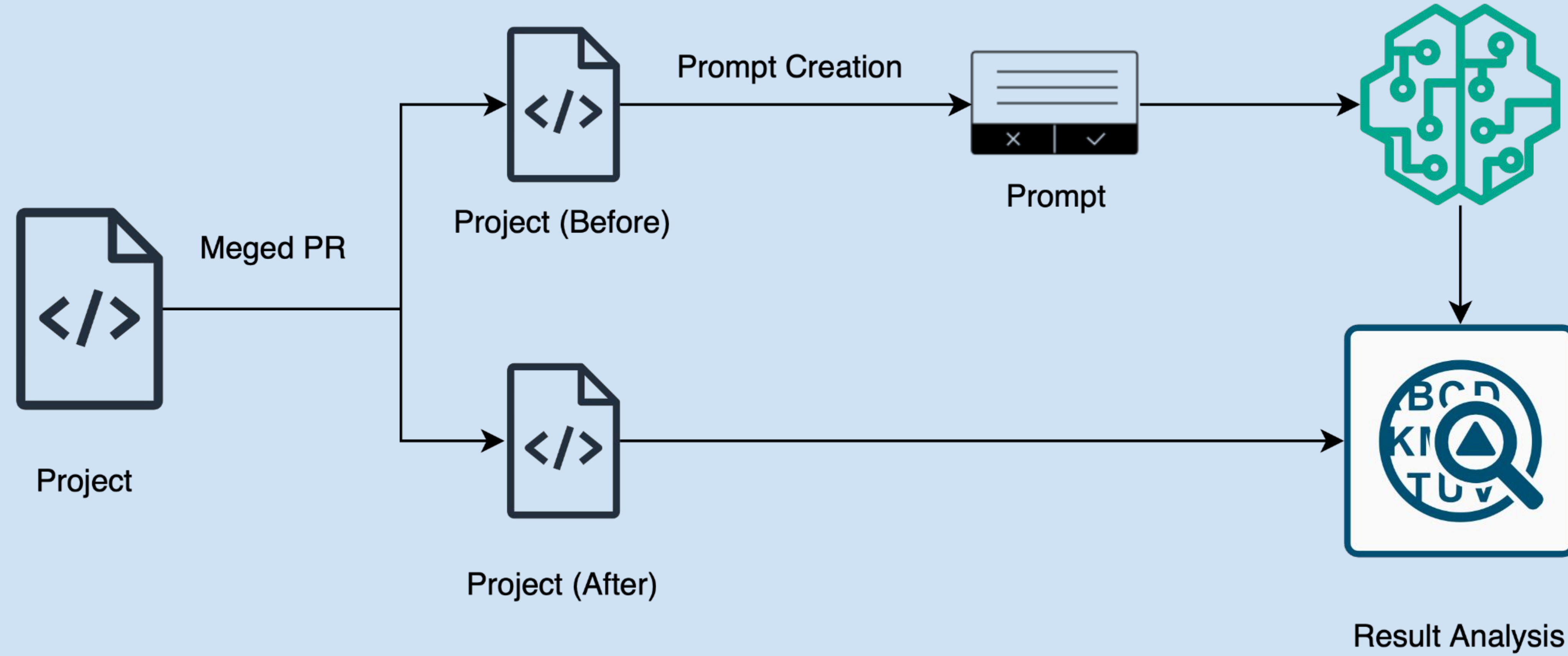
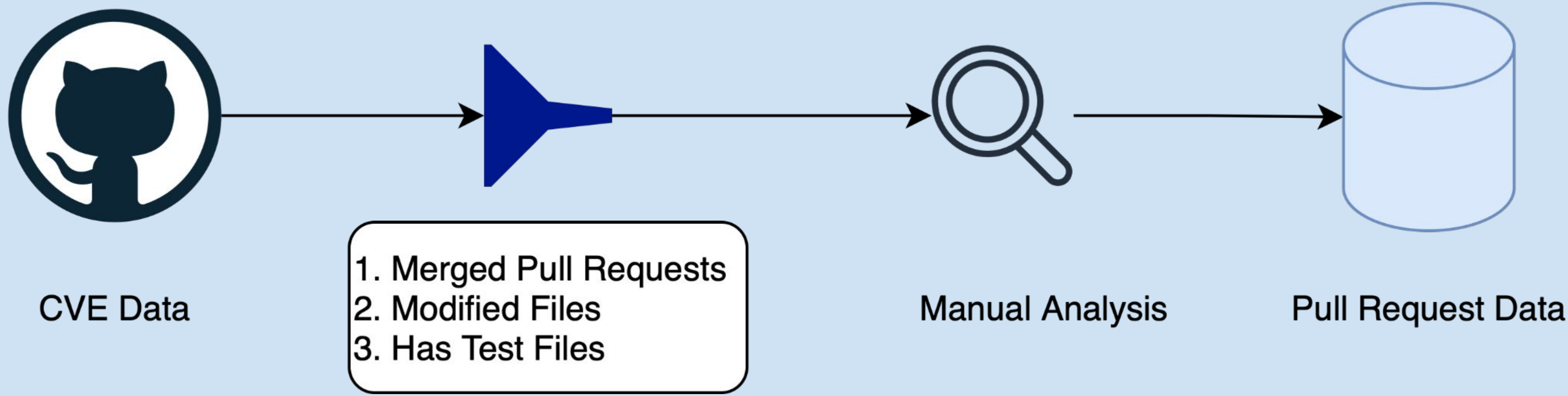
Prompt: Fixing the vulnerability

Generated code

CVE: A CVE (Common Vulnerability and Exposures) is a standardized identifier for publicly known information security vulnerabilities and exposures.

CVE-ID	CVE-2018-0101 Learn more at National Vulnerability Database (NVD) • CVSS Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings • CPE Information
Description	A vulnerability in the Secure Sockets Layer (SSL) VPN functionality of the Cisco Adaptive Security Appliance (ASA) Software could allow an unauthenticated, remote attacker to cause a reload of the affected system or to remotely execute code. The vulnerability is due to an attempt to double free a region of memory when the webvpn feature is enabled on the Cisco ASA device. An attacker could exploit this vulnerability by sending multiple, crafted XML packets to a webvpn-configured interface on the affected system. An exploit could allow the attacker to execute arbitrary code and obtain full control of the system, or cause a reload of the affected device. This vulnerability affects Cisco

Secure Software-Bench
(Work in Progress)



PRESENTER:
AJ Jones and Verite Mugabo Verite
Department of Computer Science and Engineering



CONTRIBUTION AND
OBSERVATION

1. Mined around 12,000 CVE data.
2. Worked with GitHub REST API to filter data.
3. Manually analyzed 102 pull requests.
4. Worked with Hugging Face models and OpenAI API.
5. Learned about crafting prompts for LLMs.
6. Current prompting technique did not result in solving CVE.

FUTURE WORK

- Will use more prompting techniques to provide appropriate context to fix the CVE.
- Will build an automated pipeline to run and test code generated by these models.

CONCLUSION

AI-assisted code generation techniques, such as GitHub Copilot, are increasingly influencing on software development. However, trusting blindly to automatically generated code can be harmful as it can produce bad code patterns and vulnerable source code. Hence, our dataset and framework can help rank the models based on their ability to solve real-world vulnerabilities.

ACKNOWLEDGMENT

As part of the CSE Summer Enrichment Program, funding for this work was provided by NSF CNS-1931962 and NASA 80NSSC21M0185. We also thank, our research mentor Mohammed Latif Siddiq, faculty advisor Dr. Joanna CS Santos and program director Arturo Russell.